

# AgentGuard

**A Supply-Chain Security Layer for Third-Party Skills and MCP Tools in Enterprise AI Agents**

## MFIN7060 GROUP INNOVATION PROJECT

**Yao Yao**

PM / Narrative Lead

**Zheng Kaibin**

Problem Research

**Wang Yuzhou**

Product Solution

**Zhou Mo**

UX / Demo

**Huang Tianjian**

Business Model

**Zhong Yang**

GTM / Organization

HKU Business School · April 2026

◀ Prev

Next ▶

SECTION 01

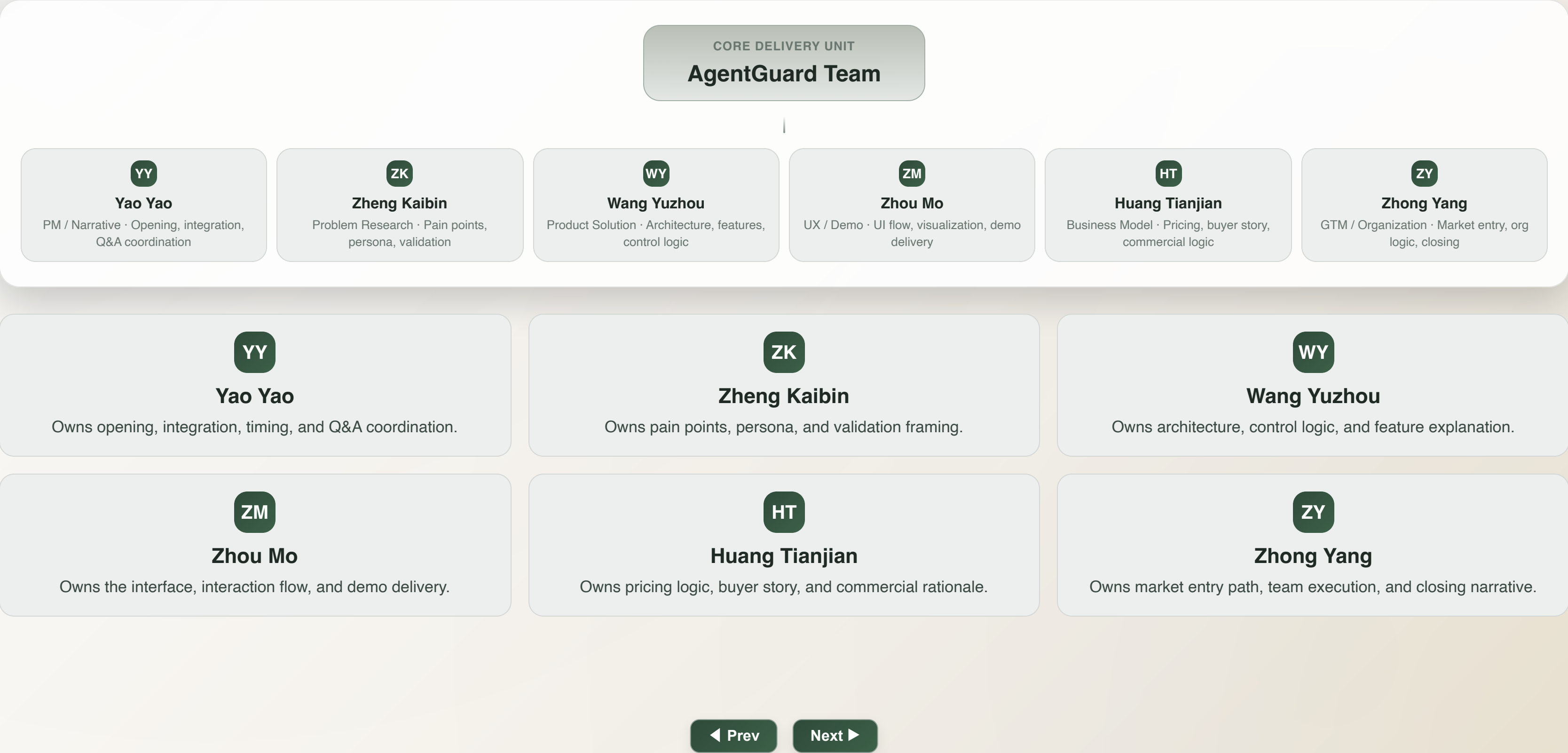
# Project Structure & Narrative

PM lead · team structure · rehearsal checkpoints

◀ Prev

Next ▶

# Six-member execution structure



SECTION 02

# Problem Research

Threat framing · category difference · user validation

◀ Prev

Next ▶

# Enterprise agents are using third-party capabilities without a trust layer



## The governance gap is simple, but operationally serious.

Enterprise agents increasingly depend on external skills and MCP tools to move faster. That dependency creates a new trust problem that most teams cannot currently govern well.

- High-impact permissions:** third-party extensions can influence file access, network access, and tool invocation.
- Low installation visibility:** teams often cannot explain what was approved, by whom, or whether it later changed.
- Weak incident traceability:** when behavior drifts, organizations struggle to prove what happened after the fact.



# Why agent extensions are different from ordinary software packages

| Dimension             | Ordinary package review                                               | Agent extension trust problem                                                                |
|-----------------------|-----------------------------------------------------------------------|----------------------------------------------------------------------------------------------|
| Declared purpose      | Usually inferred from code, version history, and dependency metadata. | Must also consider descriptions, capability declarations, and behavior claimed to the agent. |
| Effective permissions | Often constrained by runtime or service boundaries.                   | May inherit broader file, network, or tool influence from the agent environment.             |
| Risk timing           | Risk is often visible at install or build time.                       | Risk may emerge later through delayed or behavior-drift actions after approval.              |
| Control model         | Static scanning and dependency checks may be enough for first review. | Requires static checks, trust signals, runtime enforcement, and auditability together.       |
| Governance question   | "Is this package safe enough to pull?"                                | "Should this extension be installed, trusted now, allowed to run, and explainable later?"    |



# Who has this problem?

## Alex: enterprise agent security lead

Needs visibility, control, and defensible governance

Alex needs a way to answer what is installed, what is risky, what was blocked, and how to explain a security event to management or audit stakeholders.

**What Alex values:** clear install decisions, runtime controls, and traceable evidence after an incident.

**Why this matters:** without a trust layer, every third-party extension increases uncertainty rather than capability.

## Ray: agent developer under time pressure

Needs a fast decision, not a long report

Ray wants to know in seconds whether a skill should be installed, sandboxed, or blocked, without waiting for a heavyweight security process.

**Lightweight validation:** the project is grounded in a real classroom MVP and a concrete developer workflow rather than an abstract policy idea.

**Design implication:** every result must be explainable enough for Alex and fast enough for Ray.

SECTION 03

# Product Solution

Architecture · control logic · MVP scope

◀ Prev

Next ▶



# Product Definition

AgentGuard is a trust layer for the AI agent supply chain, covering everything including skills, MCP tools, dependencies. Instead of a one-time check, we manage risk across the full lifecycle — before installation, during installation, and at runtime.

## Defense Principles

**PRINCIPLE 1**  
**Zero Trust Architecture**

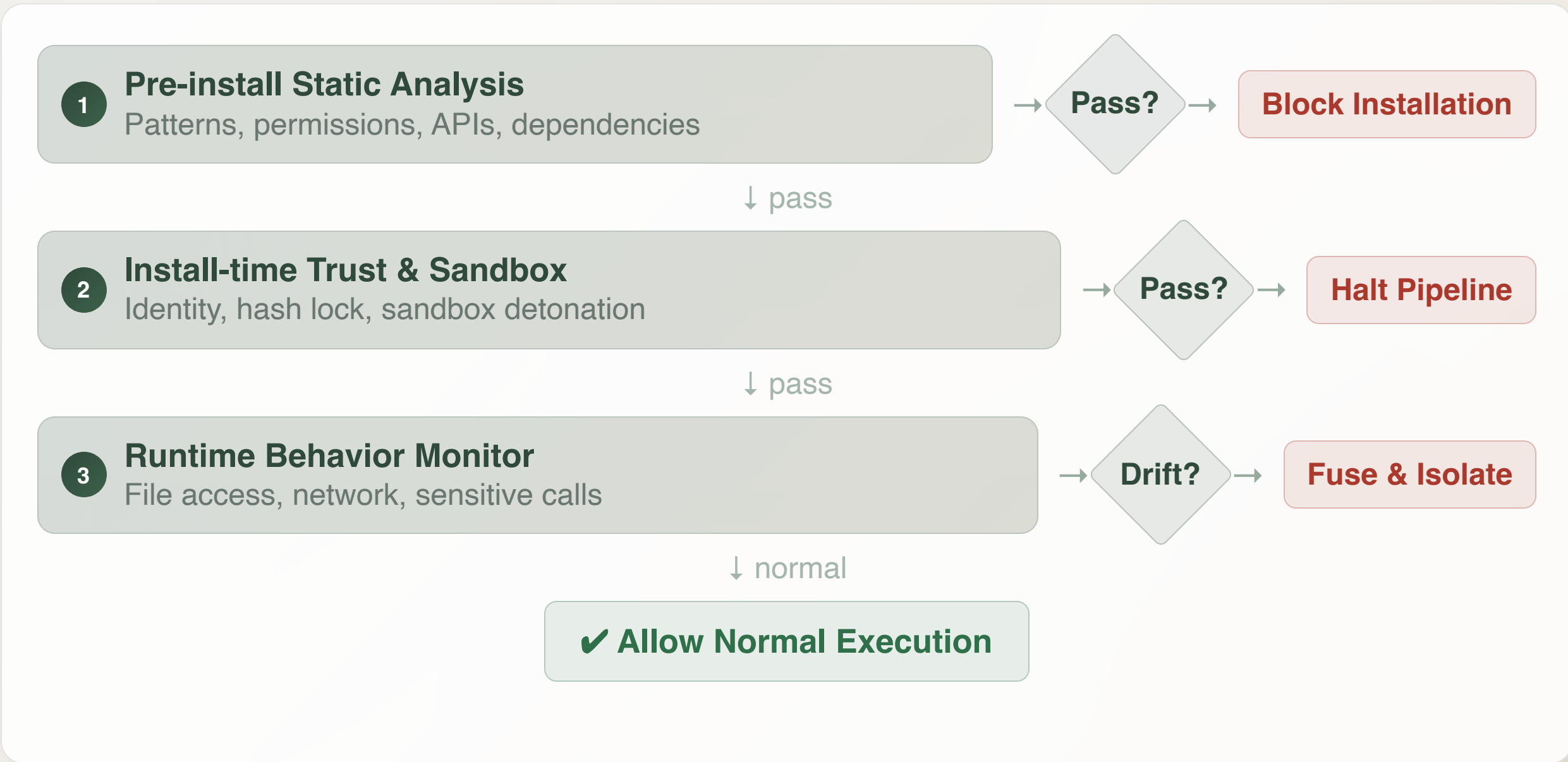
Never trust, always verify every third-party skill before and after installation.

**PRINCIPLE 2**  
**Principle of Least Privilege**

Strict validation of **minimal permission requirements**. No skill gets more access than declared.

**PRINCIPLE 3**  
**Full-Stack Traceability**

Maintaining a verifiable audit trail for **every runtime action**. Explainable evidence, not just verdicts.



# Product Structure

## SUPPLY-CHAIN INGESTION



## 3-LAYER DEEP DEFENSE ENGINE



## UX / UI & OUTPUT



### OpenClaw Skill Source Code

Upload & access skill packages



### MCP Tools & Configurations

Server configs & tool manifests



### System Prompt Templates

Agent instruction files

### Dependency Auditor

Checks different types of files

- package.json.
- requirements.txt.
- ClawHavoc-style dependency lockfiles

### 1 Pre-install Static Analysis

Before any installation, we scan for code, permissions, APIs and risky dependencies. If there were anything suspicious, We will take a clear action.

suspicious patterns

declared permissions

sensitive API refs

risky dependencies

risk level & evaluation

Output → risk level, explanation, clear action: allow, block, or deny not just a score

### 2 Install-time Trust Verification & Sandbox

Verify whether the component is trustworthy now. For anything that passes but looks risky, we detonate it in a sandbox before allowing installation to proceed.

trust verification

sandbox simulation

hash lock

change tracking

source & maintainer metadata

Output → proceed to install or halt pipeline

### 3 Runtime Behavior Monitor

Continuously observe file access attempts, network requests, sensitive tool calls, If behavior departs from what was declared, we can immediately block or isolate it in real time.

file access

network egress

sensitive calls

fuse & isolate

cleartext evidence

Output → risk score, recommended action, audit trail



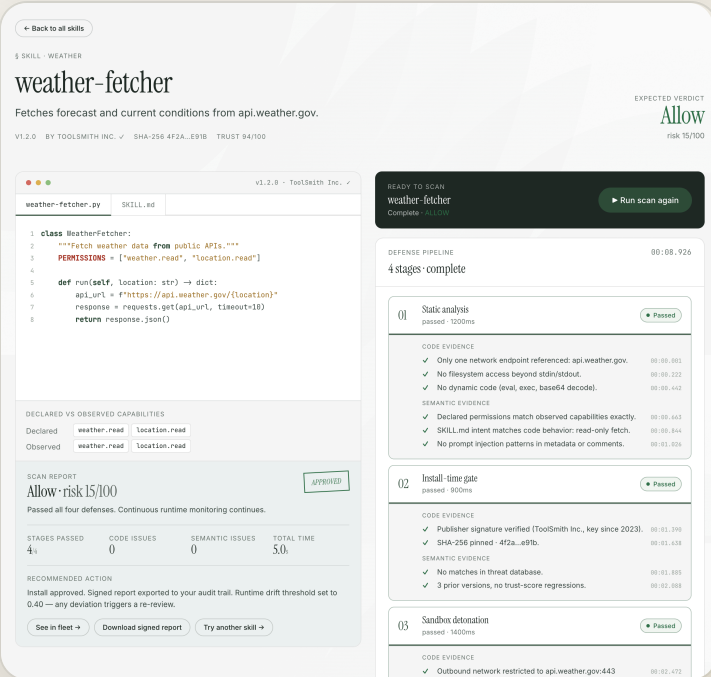
### Attack-Path Visualiser

Shows showing threats as a cleastep-by-step sequence and userbehavior in a traceable, annotatedneline.



### Real-time Interception Log

Logs intercepted events with risk score, evidence, and recommended action for transparency.



User

◀ Prev

Next ▶

SECTION 04

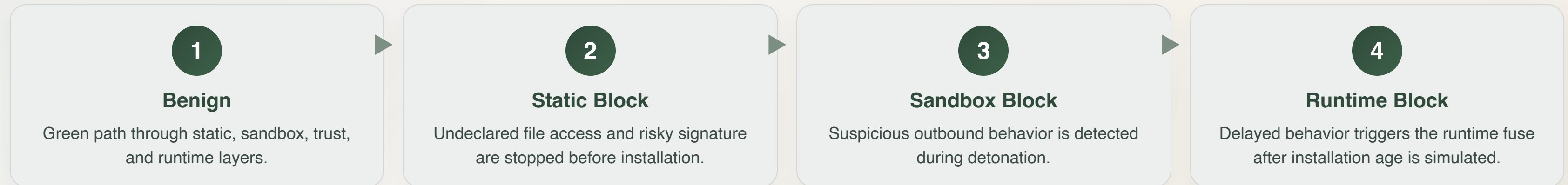
# UX / Demo

Live demo · product UX · visible reasoning

◀ Prev

Next ▶

# Product UX — one product, four outcomes



## The UX is designed for two audiences at once.

- 1 Fast judgment:** developers need a decision in seconds, not a long compliance report.
- 2 Visible reasoning:** every blocked outcome is paired with stage-specific evidence and an operator-readable explanation.
- 3 Low-friction safe paths:** the goal is not to stop all third-party use, but to make trusted adoption manageable.
- 4 Dashboard value:** security leads see what is installed, what is risky, and what has already been contained.

◀ Prev

Next ▶

# Standalone product demo

## Embedded AgentGuard Trust Platform

Standalone demo loaded from the local project file.

Standalone HTML



Platform

Scanner

Fleet

Incidents

Customers

Pricing

Sign in

Book a demo →

Tweaks

◀ Prev

Next ▶



SECTION 05

# Business Model

Product ladder · pricing logic · monetization

◀ Prev

Next ▶

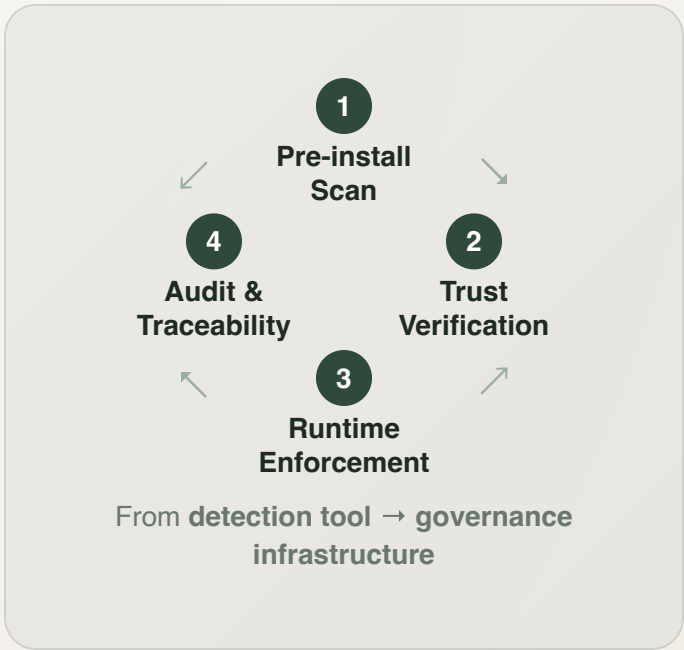


# AgentGuard — Business Model

## ♥ Value Proposition

Enable enterprises to scale AI agents safely with full visibility, control, and accountability.

- **SMEs:** Plug-and-play enterprise-grade protection
- **Enterprises:** Runtime control + compliance + auditability
- **Developers:** Instant risk scoring with minimal friction



## Why This Wins

### Traditional Tools

- ✗ Static scanning only
- ✗ No runtime control
- ✗ No auditability

*"The CrowdStrike for AI agent supply chains."*

### Without AgentGuard

- ✗ Data not guaranteed safe
- ✗ No effect-based detection

## \$ Revenue Streams

**Subscription** (primary) — Team \$20/agent/mo · Enterprise \$50–100/agent/mo

**Certification** — Skill Verified badge: \$99–499/skill

**High-value services** — Compliance reports \$20K–100K/yr · Threat intel \$10K–50K/yr

## 📍 Go-To-Market

**Developer-led growth** + Free Scanner (CLI/API)

**Partner adoption** — ClawHub / SkillsMP marketplace integration

**CISO enterprise sales** — Audit dashboards + compliance reports

## 👥 Customer Segments

**SMEs** using AI agents (entry)

**AI-native startups**

**Enterprises** with compliance needs (core revenue)

**Marketplaces** — ClawHub / SkillsMP / Cloud platforms

## 📦 Cost Structure

**R&D (~60%):** ML model training / scanning engine / runtime monitoring

**Infrastructure (~15%):** Cloud compute / sandbox clusters

**Security Research (~10%):** Threat taxonomy / Bug Bounty

**Sales & Marketing (~10%) · G&A (~5%)**

## 🏠 Key Resources & Moat

**Proprietary** risk detection models

**Behavioral dataset** (skills + prompts + runtime logs)

**Human Capital:** Researchers & AI engineers

**Distribution Platform** & open-source CLI

## 📈 AgentGuard = Agent Supply Chain Security Platform

Securing **Skills + MCP Tools + Prompts** across the full lifecycle

From detection tool → governance infrastructure → compliance platform

**Platform revenue: Security rules marketplace 30% take rate · Y3 target: \$40M ARR / EBITDA +45%**

◀ Prev

Next ▶

# Business model — what the core product ladder looks like

## Free Developer Scanner

### Adoption & Education

- Limited installations and static scans for individual developers
- Creates awareness while teaching users what "safe installation" means
- Supports product-led discovery without a heavy sales motion

## Team Tier

### Visibility & Monitoring

- Shared dashboard, unlimited scanning, and basic monitoring
- Re-scan triggers and lightweight review flows for growing teams
- Natural upgrade point once multiple agents or operators are involved

## Enterprise Tier

### Control & Auditability

- Advanced policies, runtime control, private deployment, and dedicated support
- Audit exports and incident evidence for governance stakeholders
- Supports enterprise buying triggers such as compliance and internal security review

What are the core offerings and who are they for?

◀ Prev

Next ▶

# Revenue logic — why this expands beyond the tier list

## Primary Revenue

Recurring SaaS subscription by tier: free developer entry, self-serve team plan, and enterprise contracts.

## Expandable Add-ons

Verified skill certification, compliance-ready reports, and threat intelligence can expand the revenue base later.

## Why It Is Credible

The monetization follows product maturity: scan first, monitor next, then govern at enterprise scale.

## Subscription Core

### Repeatable Revenue

- The main business is still straightforward SaaS pricing
- Customers pay for visibility, control, and auditability
- No speculative forecasting is needed to justify the model

## Service Expansion

### Higher-Value Workflows

- Compliance-ready reporting for governance teams
- Certification for trusted skills or marketplace review
- Threat intelligence for repeated monitoring customers

## Commercial Fit

### Buyer Maturity

- Developers start with scans
- Teams buy workflow visibility
- Enterprises buy governance and evidence

SECTION 06

# GTM Path & Closing

Adoption path · channels · final claim

◀ Prev

Next ▶

# GTM Strategy — Product-Led Growth (PLG)

## Build Awareness

**Action:** Launch a free Developer Edition with limited scan credits.

**Goal:** Attract the developer community and establish initial word-of-mouth in technical circles.

## Convert Teams

**Action:** Introduce a Team Edition with visual dashboards and basic monitoring.

**Goal:** Meet core team collaboration needs and achieve initial conversion from individual users to teams.

## Win Enterprises

**Action:** Release an Enterprise Edition with SSO integration, audit exports, and private deployment.

**Goal:** Serve large enterprise clients and unlock scalable commercial value across the full lifecycle.



## PLG Framework

From Individual Developers to Enterprise Clients, a Scalable Growth Journey.

## Conversion Path

### 1 Free Tier

Limited scans, user acquisition & market education

### 2 Team Edition

\$20/agent/mo, dashboard + monitoring (Self-Service)

### 3 Enterprise

Custom pricing, audit + SSO + private deploy (KA Sales)



# Marketing Strategy — Building Brand & Driving Growth

## Brand & Content Marketing

### Category Building

- **Establish Technical Authority** — Premium technical blog analyzing AI Agent security threats
- **Publish Industry Whitepapers** — In-depth research reports targeting key industries to build thought leadership

## Channels & Promotion

### Developer Penetration

- **Developer Community** — Participate in GitHub & Stack Overflow to build close connections with core developers
- **Summits & Partnerships** — Sponsor security conferences, collaborate with tech media & KOLs to amplify brand

## Product-Led Growth (PLG)

### Conversion Engine

- **Optimize Free-Tier UX** — Ensure new users can "plug-and-play," lowering the barrier to entry
- **Conversion & Viral Loop** — Guide upgrades to premium features, encourage sharing of scan results for low-cost acquisition

Free tier → self-serve team adoption → enterprise security / governance sale

◀ Prev

Next ▶



# AgentGuard is a focused trust layer, not a vague AI security claim.

The project stays narrow enough to defend academically, concrete enough to demonstrate technically, and structured enough to show a credible path from problem to product.

Third-party skills + MCP tools · working MVP · defensible classroom narrative